GREATER NEW YORK HOSPITAL ASSOCIATION
PRESIDENT, KENNETH E. RASKE • 555 WEST 57TH STREET, NEW YORK, NY 10019 • T (212) 246-7100 • F (212) 262-6350 • WWW.GNYHA.ORG

June 16, 2025

Dr. Mehmet Oz
Administrator
Centers for Medicare & Medicaid Services
US Department of Health and Human Services
Attention: CMS-0042-NC
PO Box 8013, Baltimore, MD 21244-8013

Re: [CMS-0042-NC] Request for Information; Health Technology Ecosystem; Vol. 90, No. 94, May 16, 2025

Dear Administrator Oz:

On behalf of the more than 220 voluntary and public hospitals and health systems in four states that make up the acute care membership of Greater New York Hospital Association (GNYHA), I appreciate this opportunity to respond to the US Department of Health and Human Services (HHS) Centers for Medicare & Medicaid Services (CMS) Request for Information (RFI) on digital health tools for Medicare beneficiaries, interoperability, and the broader health technology infrastructure.

We commend CMS for addressing digital health innovation. This holds great promise in improving the connectivity of currently siloed data systems, easing administrative burden, and—most importantly—enhancing patient outcomes. This effort, however, must be balanced against the financial cost of rapid adoption, particularly for under-resourced health systems, and the risks posed by unregulated tools.

With targeted incentives and strong safeguards, our members can maximize the potential of health technology for Medicare beneficiaries and others.

We appreciate the opportunity to inform CMS's policy development. Our detailed responses to the provider-focused questions are attached.

Sincerely,

Kenneth E. Raske

Detailed Comments

Digital Health Applications

Tools for Patients

All GNYHA members offer patients digital health tools developed by their electronic health record (EHR) vendors: most commonly, patient portals. These portals continue to evolve as EHR vendors add new features that enhance communication and data access for patients. Some GNYHA members offer other digital health tools directly to patients, including platforms for remote patient monitoring.

The broader use of digital health applications, however, is largely patient-driven. Commonly, patients and their caregivers download mobile apps that allow them to view their health data. Many of these apps also enable patients to track information such as symptoms, vital signs, exercise, or medication adherence, which they may share with their care teams. Hospitals have also seen a steady increase in requests from patients to connect personal digital health apps directly to hospital EHRs. This trend reflects both increased consumer interest and shifting Federal policy. For example, the Office for Civil Rights (OCR) has affirmed that the Right of Access obligations in the Health Insurance Portability and Accountability Act of 1996 (HIPAA) require hospitals to transmit data to any patient-designated app.

Patient interest in these tools signals a desire to engage more actively in care. However, it also raises significant privacy and security concerns for both patients and providers. Most patient-facing apps that are not affiliated with EHR vendors fall outside the protections of HIPAA and other applicable privacy laws. Notably, many patients do not realize that HIPAA does not apply to these tools. As a result, they may mistakenly believe their health data is protected when in fact it may be used for purposes such as marketing or research, often without consent or meaningful notice. Of note, the Federal Trade Commission (FTC) rule governing health apps only extends as far as requiring apps to notify consumers of a breach. It does not impose privacy or security standards. Thus, in the event of a data breach, patients may have limited or no legal recourse. When data is used inappropriately or a breach occurs, it can erode patient trust in the entire health care system.

A significant barrier for patients is the lack of patient access to enabling technology (*e.g.*, broadband, devices, and Wi-Fi). In addition, the ability of hospitals to provide such tools to patients is limited by hospital resources. Well-resourced hospitals are more likely to have the administrative and financial capacity to purchase products from digital health vendors under agreements that include appropriate liability and insurance provisions, for example. Additionally, every time a hospital seeks to procure a new digital health tool, it must deploy significant time and resources to review the security features of such apps, particularly those that patients wish to connect directly to the EHR.

We encourage CMS to work with other agencies to expand broadband, device, and internet access, particularly in underserved communities. Until the infrastructure is in place and maximally accessible, CMS should not impose any additional requirements on hospitals to provide or support such technology.

Also, given the significant privacy and security concerns these tools raise, GNYHA urges CMS to work with the FTC to determine how health apps could be subject to the same privacy and security standards as hospitals. We also ask CMS to collaborate closely with the Assistant Secretary for Technology Policy,

Office of the National Coordinator for Health Information Technology (ASTP/ONC) to educate both providers and patients on the practices of these tools. Such efforts would help patients better understand how their health information is used, stored, and shared. Notably, this type of transparency would also support hospital efforts to evaluate and vet third-party digital health products more effectively.

Tools for Providers

For many under-resourced hospitals, a significant obstacle to using innovative applications for physician workflows is the cost of upgrading their EHRs and/or procuring new tools. To mitigate this, CMS could subsidize the cost of acquiring new technology, like certified EHR technology (CEHRT) was first incentivized to ensure adoption.

Well-resourced hospitals benefit from innovative, EHR-embedded tools that support clinical documentation, billing, and quality reporting. These tools are ideal from a workflow perspective because they are embedded in the EHR itself, making them easy to access or enabling them to operate seamlessly in the background.

EHR vendors are considered business associates of hospitals and are therefore subject to HIPAA. Thus, the goals and requirements applicable to providers and EHR developers are aligned.

In contrast, there are many digital health tools for improving provider workflow that are not offered by EHR vendors, but rather technology companies that are not regulated by HIPAA. These non-HIPAA covered digital health tools present additional challenges for hospitals, beyond cost, particularly protecting patient privacy and addressing security concerns. Negotiating business associate agreements (BAAs) with these vendors can be difficult, even for larger health systems, as these companies have no incentive or desire to subject themselves to HIPAA's requirements. Our members have reported instances in which technology vendors refused to sign BAAs, often disputing whether individually identifiable information is involved. This issue is especially pronounced with artificial intelligence (AI) vendors, who may receive de-identified data from hospitals but possess the means to re-identify it using external data sets.

While we welcome CMS's efforts to move the industry forward to a place that favors more health technology innovation, hospitals—as the regulated and patient-facing entities—bear the liability if breaches occur, including enforcement actions and private litigation. We strongly believe there must be a balancing of the risk when integrating non-HIPAA regulated tools. We ask that CMS work with the FTC and OCR to consider how these non-HIPAA regulated digital health tools can bear some of the risk, perhaps by modernizing HIPAA to provide that some of these tools may be HIPAA covered entities and amending the de-identification standards to address re-identification using other data sources.

Interoperability

Over the past decade, there has been significant progress toward greater interoperability among health care providers. This progress is largely attributable to the widespread adoption of CEHRT, which CMS incentivized through the Promoting Interoperability (PI) Program (formerly Meaningful Use). The Information Blocking Rule has also advanced interoperability efforts, particularly in promoting the exchange of clinical notes.

Clinicians support increased interoperability, as access to patient records is essential for delivering safe, high-quality care. At the same time, our members would also appreciate having the technology available to segment certain information related to specific sensitive care from a record, when clinically appropriate. While CEHRT is currently required to provide some segmentation technology, it has limited application to the document level. Yet, certain states like New York are attempting to require segmentation of records at a more granular level, such as at the clinical element level. We ask CMS to work with ASTP/ONC to advance the CEHRT standards to give providers flexibility in segmenting records when clinically appropriate. If ASTP/ONC does not lead on this issue, there will be a patchwork of state laws regulating CEHRT across the country.

In addition, interoperability is limited in certain areas, especially as it concerns exchange with entities outside the traditional health care delivery system or those that were left out of incentives to adopt CEHRT. For example, laboratory results are sometimes transmitted as PDFs, which are not easily integrated into EHRs. Community-based organizations (CBOs) often collect important patient information that does not fit into structured EHR fields. Additionally, reporting to PHAs remains burdensome and largely one-sided, despite the public health need for bi-directional data exchange.

To address these issues, we urge CMS to consider reorienting the PI Program away from requiring more out of hospital technology, as the program has evolved far beyond its initial scope. Today, EHR vendors seek certification only because hospitals and other providers are required to use CEHRT to participate in Medicare payment programs. CEHRT is now widely adopted by traditional health care providers, yet the PI Program's requirements continue to expand. As the program grows, so do the CEHRT technical standards and, consequently, the costs to hospitals for EHR system upgrades.[1]

Instead, CMS should consider certifying application programming interfaces (APIs) that allow non-traditional health care entities—such as laboratories, CBOs, and PHAs—to connect securely to CEHRT. These APIs should support privacy protections and safeguard hospital systems while expanding the scope of interoperable data sources.

Third-Party Products that Modify Hospital Systems

The type of access envisioned in this section (*i.e.*, permitting broad access to third-party products) would introduce significantly greater cybersecurity risk. As previously mentioned, most third-party patient products are non-HIPAA–covered applications and therefore lack the same level of cybersecurity protections as hospital systems. When a hospital permits a third-party product—one with which it does not have a contractual relationship—to connect to its systems, the connection is typically limited and designed to enable data sharing between the patient and hospital. It is unlikely that a hospital would allow a third-

[1] In addition, certain requirements within the PI Program—such as the Security Risk Analysis measure—are duplicative of existing obligations under HIPAA. Other newer objectives, including antibiotic use and resistance reporting, often require hospitals to invest in technology outside their EHR systems, which is problematic in light of how much hospitals have invested in CEHRT. Moreover, the ability to meet some objectives, such as Prescription Drug Monitoring Program reporting and engagement with public health agencies, depends on whether State and local governments have the necessary infrastructure to connect (preferably via FHIR) with hospital CEHRTs. In many cases, they do not.

party tool to make changes to its systems without a contractual relationship that allows for proper vetting of the vendor's security features, liability protections, and insurance requirements.

Cybersecurity is a critical and growing concern for hospitals. Hospitals dedicate significant time and resources to protecting their systems against rapidly evolving cyber threats. A major cybersecurity incident could take hospitals offline and compromise patient care. The topics outlined in this RFI all have a cybersecurity dimension, and CMS should consult with the relevant Department of Health and Human Services components for input from the security perspective as it evaluates the RFI responses.

Data Exchange

Fast Healthcare Interoperability Resources (FHIR) APIs

We do not have comprehensive data on the current state of adoption for each FHIR API identified in the RFI. However, it is our understanding that Bulk FHIR has not fully matured. This has significant implications for public health agency participation in the Trusted Exchange Framework and Common Agreement (TEFCA), which we address in greater detail below.

While GNYHA members conceptually support FHIR-based exchange—particularly its ability to streamline data sharing, reduce burden, and support auditing—successful adoption depends on more than technical readiness, particularly for payer APIs. Many hospitals are reluctant to grant payers any level of access to their EHRs, due in large part to longstanding trust issues stemming from historically adversarial relationships. Hospitals are concerned that payers could use APIs to more easily retroactively challenge claims, deny coverage, or initiate audits rather than enhance care coordination.

Moreover, at present, there is also a misalignment between the FHIR standards supporting payer APIs and those required for CEHRT. In this regard, CMS recommends—but does not require—regulated payers to use the Da Vinci Project standards in their electronic prior authorization (PA) APIs. Conversely, CMS has proposed (but not finalized) that CEHRT must use the Da Vinci Project standards. Further complicating matters, despite this misalignment, hospitals must attest under the PI Program in 2027 that they exchanged data with a payer for electronic PA or face significant penalties.

Finally, we note that FHIR transmission itself is highly complex. Fully understanding and implementing FHIR requires multidisciplinary expertise across privacy, cybersecurity, quality reporting, and health information exchange. This expertise is particularly difficult for less-resourced hospitals to acquire and maintain. Moreover, FHIR standards vary in maturity and are at different stages of testing and adoption.

We therefore encourage CMS to align the technical standards for payer APIs and CEHRT; as threshold action, collaborate with ASTP/ONC to establish a certification or standard vetting process for payer APIs;[2]

---

[2] A certification or standard vetting process for payor APIs would help build confidence in the payer APIs and could foster a payer API marketplace that benefits State Medicaid agencies—who are subject to these requirements—as well as non-CMS-regulated payers pursuing similar data exchanges. Specifically, as to Medicaid, hospitals have historically lacked access to claims data for their Medicaid patients. We understand that strict Federal privacy and security rules present challenges to data sharing. CMS should consider approving APIs for State Medicaid agencies that address those challenges.

and lead industry education efforts and promote transparency in FHIR-based exchange, the development of checklists, plain-language technical guidance, and vendor engagement tools. These efforts would go a long way to meaningfully support hospitals as they work toward building a robust, interoperable exchange infrastructure based on FHIR standards.

TEFCA

The TEFCA rollout is only just beginning across our membership and is currently limited to hospitals that use Epic as their EHR vendor. These members are in the process of receiving and reviewing their TEFCA agreements, and as a result, active data exchange has not yet reached a level that allows for meaningful evaluation of its effectiveness.

That said, our members generally appreciate the foundational structure TEFCA provides: it enables nationwide data exchange under standard operating procedures; supports bi-directional data exchange; and is based on specifications that could allow for exchange that can be audited and monitored. Replicating this structure outside of TEFCA would likely require hospitals to engage with multiple public and private health information exchanges, often involving a patchwork of layered legal agreements.

To date, much of the TEFCA conversation has focused on data sharing for treatment purposes. Our members appreciate the additional guardrails that ASTP/ONC has included for treatment-based exchange, particularly in light of their concerns around payer access to hospital data. We ask CMS to work with ASTP/ONC to determine whether further protections can be implemented to address concerns about cross-state sharing of sensitive health information, including reproductive health care information. A potential solution is requiring the TEFCA Qualified Health Information Networks to provide patients with an accounting of disclosures similar to the requirement for HIPAA-covered entities. Like with segmentation, if the Federal government does not take the lead on this issue, then some states will be reluctant to participate in TEFCA and, moreover, may enact their own laws that complicate or deter provider participation.

In addition, expanding TEFCA's capabilities to support exchange for non-treatment purposes—particularly public health reporting—could offer meaningful benefits to hospitals. The current public health data reporting landscape remains burdensome, duplicative, and largely reactive rather than preventative.

PHA technology infrastructure varies widely across jurisdictions. While some members are able to transmit data to the Centers for Disease Control and Prevention using CEHRT, these instances are limited. Many state and local PHAs continue to rely on outdated technologies. Our members frequently report that they must submit data manually, often in PDF format, and then follow up via phone or fax. In New York State alone, hospitals must navigate more than a dozen separate mechanisms to meet reporting requirements.

Notably, public health data exchange must be bi-directional to be effective. While hospitals routinely provide data to support government public health initiatives, the information is rarely returned in a way that supports hospitals' own efforts related to those same initiatives. Every PHA should have a clear data strategy aligned with its public health objectives and the needs of the populations it serves.

TEFCA is well positioned to support this type of strategy by reducing provider reporting burdens and enabling meaningful bi-directional data exchange. However, we understand that many state and local PHAs

are hesitant to participate in national interoperability initiatives, citing concerns about the limited maturity and adoption of bulk FHIR standards. According to PHAs, these standards are essential for retrieving large volumes of data, which is a critical capability for population health efforts. We also understand that the TEFCA public health use cases are limited compared to the full breath of PHA work.

We therefore urge CMS to do the following: incentivize or otherwise encourage state and local PHA participations in TEFCA; clarify the current state of bulk FHIR standard maturity and adoption; allow state and local PHAs to enter into agreements with TEFCA participants to exchange data beyond the current TEFCA public health use cases where supported by law; and establish a certification or vetting process for APIs that PHAs could use to participate in TEFCA as an alternative to investing in a technology system.

Information Blocking

The information blocking rule has undeniably advanced the industry's efforts to share more electronic health information, particularly clinical notes. However, hospitals were able to comply in large part because their EHR systems—into which they have made significant investments—enabled them to do so. Operationalizing the rule also required hospitals to assemble multidisciplinary teams—including IT, operations, clinical, and legal staff—to develop and implement policies and procedures. In many cases, hospitals also incurred additional costs by engaging outside counsel and consultants to ensure compliance.

Despite these efforts, key elements of the rule and its exceptions remain poorly understood. One area of confusion is the "knowing" intent standard. Questions about what actions satisfy this threshold arise most frequently in the context of complex vendor contracts; for example, negotiating confidentiality terms in a data use agreement with a third-party technology company. Although hospitals are likely to be supported by HIPAA and state law in seeking restrictive terms, vendors sometimes push back and cause confusion over whether the inclusion of certain terms constitutes information blocking. This situation is exacerbated by the lack of guidance on the topic.

Another area of concern is the scope of the preventing harm exception. Clarifications issued by ASTP/ONC state that this exception only applies when a patient faces the risk of *physical* harm. Psychological or social harm, even when foreseeable, do not meet the threshold. For some hospitals, this raises uncertainty around whether they can delay the release of certain sensitive test results—such as HIV or cancer-related findings—until the patient's treating provider has the opportunity to discuss the results in person. This concern is heightened when such results are part of a broader diagnostic series, where each test may be conducted and released separately, even though all are required to reach a diagnosis. Hospitals often have limited insight into how patients may react to sensitive results, making it difficult to assess the risk of physical versus emotional harm.

In the absence of clear guidance, hospitals may interpret these provisions differently. This creates inconsistent experiences for patients, particularly in urban areas like New York City, where individuals often receive similar care testing from multiple providers. It creates a situation where access to information is different depending on the provider the patient sees. We urge CMS to work with ASTP/ONC to provide clarity to hospitals on this narrow but important issue.

As for oversight and enforcement, the penalties for violating the information blocking rule are disproportionately severe. These include substantial Medicare reimbursement reductions and exclusion

from the Medicare Shared Savings Program. In addition, many of the actions now subject to penalties are already enforceable under existing regulatory frameworks. For example, the most common complaints involve patients claiming they were denied timely access to their health records—a violation of HIPAA's Right of Access, which is already actively enforced by OCR. This is a prime example of overlapping mandates that do not align or complement each other but instead create unnecessary redundancies.

While ASTP/ONC has published aggregate statistics on complaint volume and type, it remains unclear how many of these complaints constitute actual violations. Rather than encouraging additional complaints, we urge CMS to work with ASTP/ONC to publish de-identified data on existing reports. Doing so would help the industry better understand which actions have been deemed violations and how the "knowing" intent standard has been met in practice. Increased transparency would promote consistent interpretation and foster more meaningful compliance with the rule.